

Introduction to Secure Multi-Account Access Architecture

By: Danuja

Introduction

This project focuses on implementing a secure multi-account access architecture using AWS Organizations. A three-account structure is established consisting of Development, Staging, and Production environments to ensure workload isolation and reduce blast radius in the event of misconfiguration or security incidents.

Service Control Policies (SCPs) are applied at the organizational level to define and enforce service usage boundaries, preventing accounts from performing actions outside approved services regardless of their individual IAM permissions.

Cross-account access is implemented using an IAM role assumption model, allowing controlled and auditable access between accounts without sharing long-term credentials. This approach supports least-privilege access while maintaining operational flexibility for administrators and deployment pipelines.

To strengthen identity security, Multi-Factor Authentication (MFA) is enforced for all IAM users, ensuring that access requires both credentials and a physical or virtual authentication factor.

Together, these controls provide a layered security model that aligns with AWS best practices for multi-account governance, access management, and operational risk reduction.

STEP 1 – Create AWS Organization

1. Login to your main AWS account
2. Go to **AWS Organizations**
3. Click **Create organization**

Done.

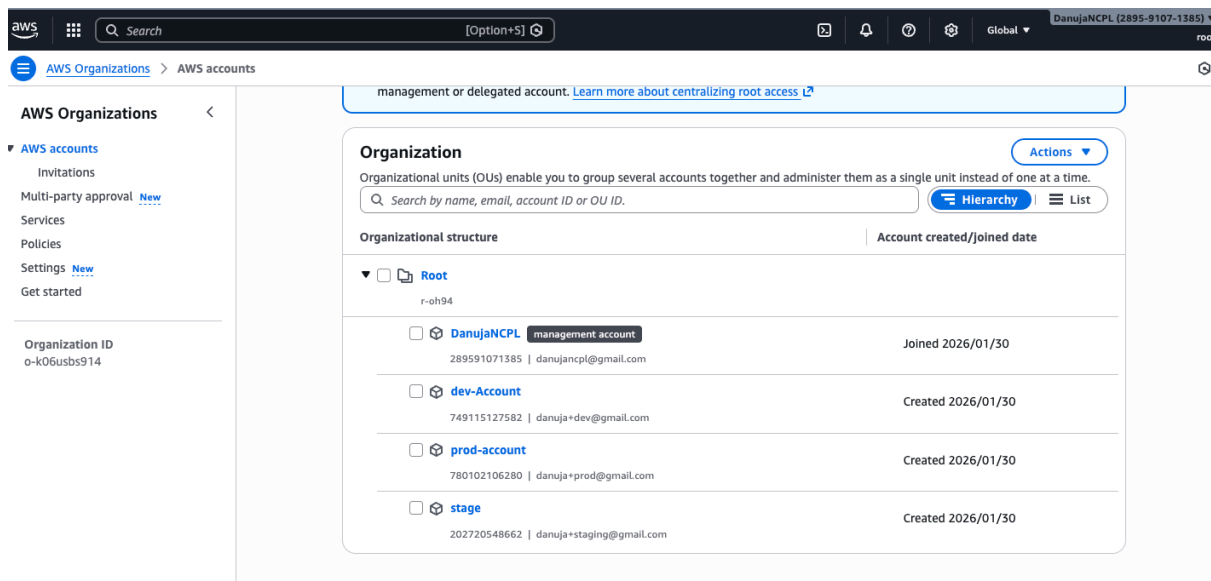
STEP 2 – Create 3 accounts

In AWS Organizations:

1. Click **Accounts** → **Add an AWS account**
2. Create:
 - Dev
 - Staging
 - Prod
3. Wait until all 3 are created

Now you have:

- Management account
- Dev account
- Staging account
- Prod account



The screenshot displays the AWS Organizations console interface. The left sidebar shows the navigation menu with 'AWS Organizations' selected. The main content area shows the 'Organization' details for 'DanujaNCPL (2895-9107-1385)'. The 'Organizational structure' tab is active, showing a hierarchy starting with 'Root' (r-oh94). Below the root, there are four accounts listed:

Account Name	Account ID	Email	Account created/joined date
DanujaNCPL management account	289591071385	danujanapl@gmail.com	Joined 2026/01/30
dev-Account	749115127582	danuja+dev@gmail.com	Created 2026/01/30
prod-account	780102106280	danuja+prod@gmail.com	Created 2026/01/30
stage	202720548662	danuja+staging@gmail.com	Created 2026/01/30

STEP 2 – Create Organizational Unit (OU)

You are on:

AWS Organizations → **AWS accounts**

Look at the **Root** line.

Do this:

1. Tick the checkbox next to **Root**
 2. Click **Actions** (top right of the list)
 3. Click **Create organizational unit**
 4. Name it:
 5. **Workloads**
 6. Click **Create**
-

STEP 3 – Move accounts into OU

Now you should see:

 **Root**

 **Workloads**

and accounts under Root

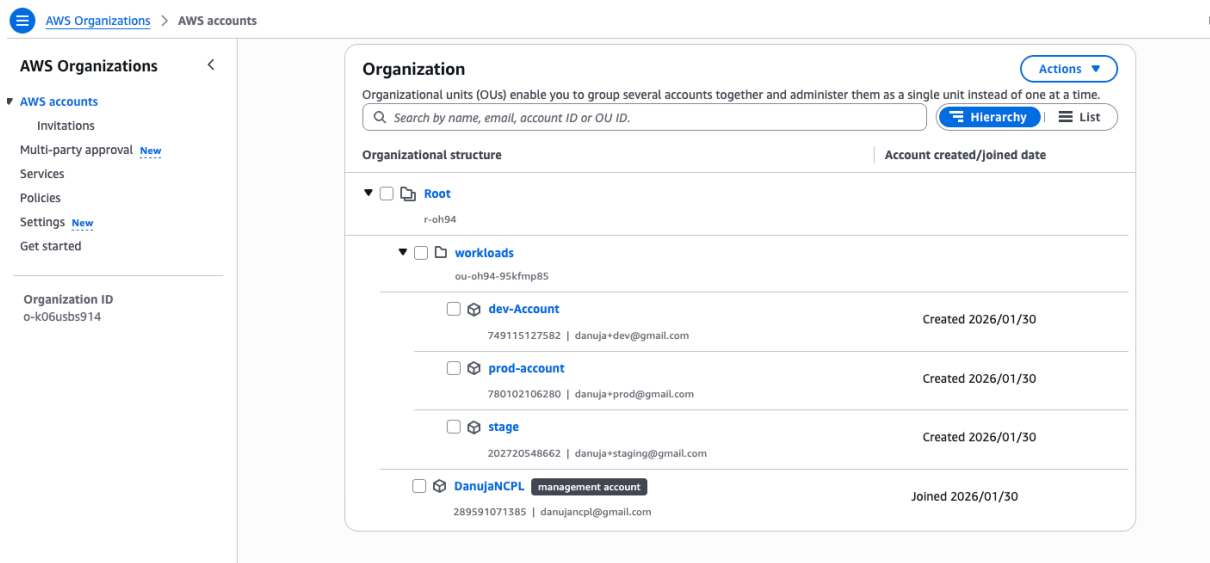
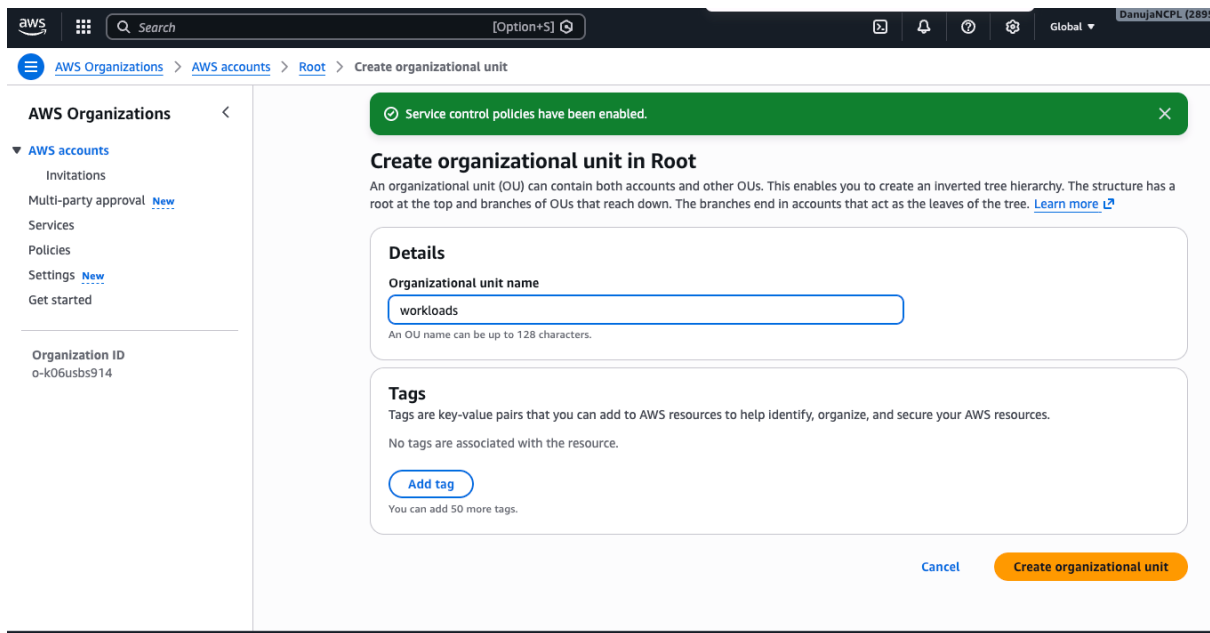
Move Dev, Stage, Prod:

1. Tick:
 - dev-account
 - prod-account
 - stage
2. Click **Actions**
3. Click **Move**
4. Select destination:
 - 👉 **Workloads**
5. Click **Move**

Now structure should be:

Root

- └─ Workloads
 - └─ dev-account
 - └─ stage
 - └─ prod-account



STEP 4 – Create SCP (Service boundary)

We will create **1 simple SCP**:

👉 Block deleting CloudTrail (security protection)

Create SCP

1. AWS Organizations → **Policies** → **Service control policies**
2. **Create policy**
3. Name: DenyCloudTrailDelete
4. Paste this:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Deny",
      "Action": [
        "cloudtrail:DeleteTrail",
        "cloudtrail:StopLogging"
      ],
      "Resource": "*"
    }
  ]
}
```

5. Save

Service control policies have been enabled.

Create new service control policy

A service control policy (SCP) specifies the maximum permissions that can be used by users and roles in your organization's accounts. An SCP doesn't grant permissions. You must still use IAM permission policies or resource policies to grant permissions. [Learn more](#)

Details

Policy name

DenyCloudTrailDelete

A policy name can be up to 128 characters and can include the following characters: a-z, A-Z, 0-9, and .-*@_.

Policy description - optional

```
{
}
```

A description can have up to 512 characters and can include the following characters: a-z, A-Z, 0-9, and .-*@_.

Tags

Tags are key-value pairs that you can add to AWS resources to help identify, organize, and secure your AWS resources.

No tags are associated with the resource.

[Add tag](#)

Successfully created the policy named 'DenyCloudTrailDelete'.

Attach DenyCloudTrailDelete to one or more targets

AWS Organization

Organizational units (OUs) enable you to group several accounts together and administer them as a single unit instead of one at a time.

Search by name, email, account ID or OU ID. [Hierarchy](#) [List](#)

Organizational structure	Account created/joined date
- Root - workloads - DanujaNCPL (management account)	Joined 2026/01/30

[Cancel](#) [Attach policy](#)

STEP 5 – Create IAM user in Management account

We create **one admin user** to assume roles.

1. IAM → Users → Create user
2. Name: org-admin
3. Access: ✓ AWS Console
4. Attach policy: AdministratorAccess
5. Create user

The screenshot shows the AWS IAM console interface. A green notification banner at the top states "User created successfully" with a "View user" button. Below this is a promotional banner for Identity Center. The left sidebar shows the navigation menu with "Users" selected. The main content area displays the "Users (2)" list. The table below shows the details of the two users:

	User name	Path	Group	Last activity	MFA	Password age	Console last sign-in
☐	danuja-user1	/	0	1 hour ago	-	8 days	1 hour ago
☐	org-admin	/	0	-	-	7 minutes	-

STEP 6 – Enforce MFA on IAM user

1. IAM → Users → org-admin
2. Security credentials → **Assign MFA device**
3. Use Authenticator app (Google Authenticator)

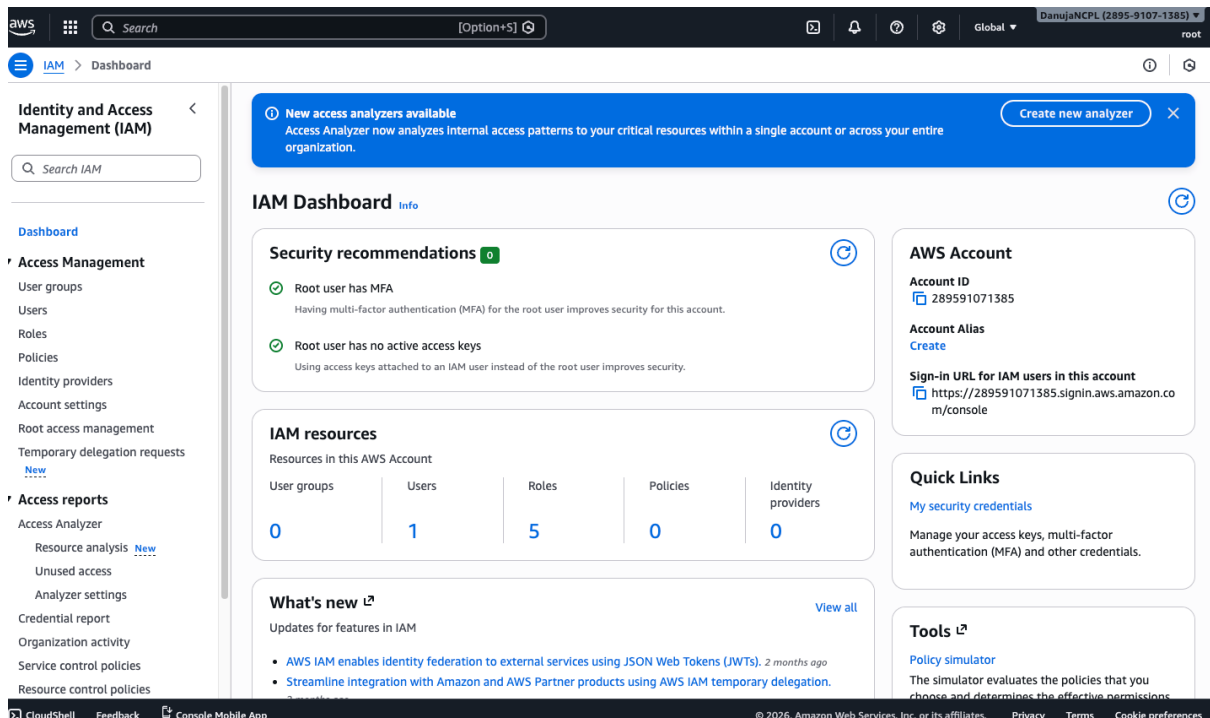
Now user has MFA.

STEP 6 – Enforce MFA on IAM user

1. IAM → Users → org-admin
2. Security credentials → **Assign MFA device**

3. Use Authenticator app (Google Authenticator)

Now user has MFA.



STEP 7 – Create cross-account role in Dev account

Login to Dev account

1. IAM → Roles → Create role
2. Trusted entity: **Another AWS account**
3. Enter **Management Account ID**
4. Role name: DevAdminRole
5. Attach policy: AdministratorAccess

Edit Trust Policy (IMPORTANT)

IAM → Roles → DevAdminRole → Trust policy → Edit:

IAM

Roles

>

DevAdminRole

1

Q

Identity and Access Management (IAM)

Q Search IAM

Dashboard

▼ Access Management

User groups

Users

Roles

Policies

Identity providers

Account settings

Root access management

Temporary delegation requests

New

▼ Access reports

Access Analyzer

Resource analysis New

Unused access

Analyzer settings

Credential report

Organization activity

Service control policies

Resource control policies

DevAdminRole info

Delete

Edit

Summary

Creation date

January 30, 2026, 12:55 (UTC)

ARN

arn:aws:iam::289591071385:role/DevAdminRole

Last activity

-

Maximum session duration

1 hour

Link to switch roles in console

<https://signin.aws.amazon.com/switchrole?roleName=DevAdminRole&account=289591071385>

Permissions

Trust relationships

Tags

Last Accessed

Revoke sessions

Permissions policies (1) Info

Refresh

Simulate

Remove

Add permissions

Q Search

Filter by Type

All types

< 1 >

⚙

☐

Policy name ⓘ

▲

Type

▼

Attached entities

▼

☐

AdministratorAccess

AWS managed - job function

4

► Permissions boundary (not set)

▼ Generate policy based on CloudTrail events